

外部AI基盤への依存と考慮点

データ主権という観点の話

セキュリティ集会 in VRChat

2026-05-09 hogehuga 脆弱性対応研究会

Who am I

hogebuga

- 脆弱性対応研究会 主催
- 脆弱性管理、安全保障、社外で話す、辺りの仕事
 - とはいえ、セキュリティコンサル/プロジェクトマネージメント/営業/教育 等もやっている

脆弱性対応研究会/脆弱性対応勉強会

- <https://www.facebook.com/groups/zeijyakuseitaioukenkyukai>
- <https://github.com/hogebuga/vulnRespStudyGroup/>
- <https://zeijyakuseitaioukenkyukai.connpass.com/>

今日のゴール：考えるきっかけを持ち帰る

この話はなぜ今？

時期	出来事
2025年8月5日	富士通、Palantir AIPとライセンス契約（防衛IT最大手経由の入口が開く）
2026年1月16日	小泉防衛大臣、ワシントンD.C.のPalantirオフィスを訪問（本社はデンバー）
2026年3月5日	高市首相、ピーター・ティール氏と首相官邸で約25分の意見交換（※）

AIの軍事利用の話が、本年初頭に表面化してきたので、それについての考察

※ 首相は3月17日の国会答弁で「同社のサービスを利用するような話は全くしていない」と明言。
会談は「日米先端技術の意見交換・表敬」の位置づけであり、調達決定ではない

今日の問い

強力なAI基盤を使うとき、データ・運用・判断の**支配権**をどう守るか？

- 「Palantirを使うべきか」ではなく、「外部基盤に依存するとき、何が起きるか」を考える話

Palantirとはどのような会社か

概要

- 2003年設立。創業資金の一部はCIAの投資部門（In-Q-Tel）
- 政府・軍・情報機関向けにデータ統合・AI意思決定基盤を提供
- 「西側民主主義のOSを提供する」と自称

主な製品

製品	概要
Foundry	組織内外のデータを統合・分析する基盤
AIP	LLMをその業務データに接続してAI化する基盤
Apollo	クラウド～エアギャップまで自動更新・監視する、DevSecOps自動化管理基盤

SIEMとデータレイクとAIエージェントを合わせて、**国家安全保障向けに作り込んだもの**、というイメージが近い

Maven Smart System：防衛版データ基盤

米軍が使っているシステム：防衛版の巨大データ基盤

- 衛星・ドローン・レーダー・OSINT などの異種データをリアルタイムで統合
- AIが状況把握・標的識別・優先順位付けを支援
- 米陸軍と約800億円規模の契約（2025年）

防衛版の「巨大データレイク＋分析基盤＋AIエージェント＋意思決定支援UI」

日本の現状

- 防衛装備庁 × Sakana AI で委託研究が進行中（2026年03月～）
 - エッジデバイス上の小規模視覚言語モデルを核に、全領域データを統合する構想
 - ドローン側で画像を処理してセンターに送るようなアーキテクチャを想定
- ただし「研究フェーズ」と「実戦運用水準」の間には大きな距離がある
- 詳細は**非公開**——何がどこまで進んでいるか外からは見えない

能力ギャップを外部基盤で埋める

外部基盤を選ぶ理由は「必要性」

- 自国・自組織にない能力を、ゼロから開発するには**相応の時間とコスト**がかかる
- 既に実用水準に達した外部基盤を活用するのは、**実務上ごく通常の調達判断**
- 問題は外部依存そのものではなく、依存の**条件と構造**にある

外部基盤が選択肢に上がる具体的な理由

- 米軍・NATOで実戦運用実績がある
- 国産ゼロからより**圧倒的に短い期間で能力を獲得**できる
- 国内ベンダ通経由で既存の防衛IT調達に**乗せやすい**

そして

外部基盤への依存は、能力上の必然から生じることが多いが、**依存が深まるほどデータ・運用・判断プロセスが絡みつき**、「使えるか」と「誰の支配下で使うか」は、別の問いになっていく

データ主権と、よくある誤解

「データ主権 = 国内サーバーに置くこと」は誤り

よくある誤解	実際に見るべきこと
国内データセンターなら安全	管理者は誰か・どの法が適用されるかも見る
暗号化していれば安全	鍵を誰が管理しているかが問題
契約に「データ返却」と書けば安心	データモデル・設定・ワークフローまで移行できるか
AIは単なる分析ツールにすぎない	推論時に情報がどこに流れるかを見る必要がある

今日の定義

データ主権

- データとそれを処理するシステムに対して、自組織が**実質的な支配・監査・退出可能性**を維持できる状態

データ主権の4層モデル

「どこか1層を守れば安心」は成立しない

層	何を見るか	具体例
① 物理的主権	データがどこに保存・処理されるか	DC所在・バックアップ・暗号鍵の保管場所
② 法的主権	どの国の法律でデータを開示させられうるか	CLOUD法・FISA・裁判管轄
③ 運用的主権	誰が管理・更新・ログ閲覧の権限を持つか	管理者権限・リモート保守・アップデート権限
④ 退出可能性	やめるときにデータ・設定を取り出せるか	エクスポート・API・監査ログの移行可能性

ポイント

- ①物理的主権 を確保しても、他の②③④のリスクは消えない
- 「国内サーバー置いたから大丈夫」は ①物理的主権 しか見ていない

① 物理的主権：「国内に置けば安全」の限界

確認すべきこと

- データセンターの物理的所在地
- バックアップの保管場所
- 暗号鍵を誰が単独で保持しているか

重要な限界

国内サーバーに置いていても以下を検討する

- 管理事業者が**外国法の管轄下**にあれば、法的主権リスクは残る
- 外国企業エンジニアが**遠隔保守アクセス**を持っていれば、運用的主権は損なわれる

この層でよくある過ち

「国内DCに置くから主権は守られる」

- → ①しか確保できていない状態を「解決済み」と勘違いする

② 法的主権：米国CLOUD法という問題

CLOUD法（2018年成立）とは

アメリカの法的管轄下にある事業者は、データの物理的保存場所を問わず、有効な法的手続きに基づき開示義務を負う可能性がある

日本への影響

- Palantirは**米国法人** → CLOUD法の管轄下にある
- 日本国内にサーバーを置いても、**この問題は解消しない**
- 英国・オーストラリアはCLOUD法の「行政協定」を締結済み
- **日本にはこの協定がない** → 法的保護の空白

つまり

- 「暗号化しても、鍵を持っている人に令状が届いたら終わり」
- 同じ構造が、クラウドサービスと法制度の間に存在する

③ 運用的主権：「誰が管理者か」問題

一番わかりやすく、一番見落とされやすい層

- アルゴリズムの**更新権限** → 意思決定の「型」を変えられる権限
- **遠隔保守アクセス** → 外国企業エンジニアが常時接続できる状態
- ログ閲覧・障害対応の**権限帰属**はどちら側か

PalantirのApollo（管理基盤）の構造

Palantir中央 → 更新パイプライン → 顧客環境（クラウド～エアギャップ）

- これが強みとして宣伝される機能
- 日本側が更新内容を**事前審査なしに適用**される構造になっていたら？

FDE（常駐エンジニア）モデルの問題

- Palantirは「Forward Deployed Engineer（FDE）」として**顧客組織内に常駐**
- 機能最適化には強いが、防衛情報システムの内部に**外国企業社員が常時アクセス**する状態

④ 退出可能性：「やめたくてもやめられない」

「データ返却30日」では退出は実現しない

Palantirの標準契約では、契約終了後30日間データにアクセスできるが、実質的な退出に必要なのは以下

- データ本体
- ワークフロー定義・データモデル仕様
- アプリケーション設定・権限管理体系
- 監査証跡・運用ドキュメント

これらが独自フォーマットで蓄積されていれば、「データ」だけ返っても移行できない

スイッチングコストの現実

使うほど、依存が深まるほど、「やめる」というコストが天文学的になる

- 退出可能性は「将来の問題」ではなく、**調達設計の時点に組み込むべき要件**

+α：AI推論の主権（新しい問題）

「データベースは国内」でも起きること

LLMを使うAI基盤では、推論実行時に以下ようになる

プロンプト + コンテキスト + 抽出データ
→ 外部LLM（OpenAI / AWS Bedrock 等）に送信
→ 推論処理が外部の法域で実施される

アプリ本体が国内にあっても、推論時に情報が外へ流れる

防衛用途で特に深刻な理由

入力に含まれる情報	機微度
作戦状況の要約	極めて高い
標的の優先順位付け	極めて高い
異常検知の判断根拠	高い

欧州3カ国の経験

英国：段階的な能力依存→複数領域展開→退出困難

- コロナ禍の緊急調達でNHSのデータ基盤にPalantirが入った（競争入札なし）
- その後、NHS Federated Data Platform の主要コントラクターに選定（約1,200億円規模）
- **医療・警察・防衛・情報**と複数領域に横断的に参入 → 退出コストが政府全体の問題に

フランス：代替を作るはずが、更新

- 国内情報総局（DGSI）のテロ対策基盤にPalantir Foundryを導入
- 国産代替（Thales）の検討もあったが、2025年12月、**結局PalantirとDGSIの複数年契約を更新**

スイス：評価プロセスで見送り

- スイス軍が内部評価報告書を作成し主権リスクを精査
- 「ローカルホスティングでも情報漏洩を技術的に防止できない」と評価
- 採用見送りという判断に至った

「使う前に決める」か「後から後悔する」か

3カ国の差は何だったか

英国・フランス — 能力獲得が先行 → リスク精査が追いつかず → 依存固定

スイス ——— 採用前に独立評価プロセス → リスクを把握して見送り

ベンダーロックインの4段階

1. 低い参入障壁で初期導入（緊急調達・国内ベンダー経由）
2. 常駐エンジニアにより組織知識がベンダー側へ外部化
3. 基幹システム化で代替コストが急上昇・随意契約の常態化
4. 多領域横断で政府全体の問題になり、退出が事実上不可逆に

共通の失敗

「使う前に決めておくべきことを、決めなかった」

日本の現状：何が整っていないか

制度的な空白が積み重なっている

問題	現状
技術主権の評価フレームワーク	防衛調達に存在しない
FOCI基準（外国の支配・影響審査）	ライセンス契約スキームへの適用が不明確
CLOUD法に相当する日米保護協定	締結されていない
国会による技術調達の監視機能	体制が不十分
デジタル庁基準との整合	行政システムの水準が防衛調達に適用されていない逆転

※FOCI: 企業が外国の意図的な影響下にあるか、または支配されているかを評価する基準

構造的な問題

- 国内最大防衛ITベンダーを経由した参入 = 外国企業審査の対象になりにくい
- 防衛大臣・首相レベルの政治接触が先行 → 技術評価が追いつかない構造

チェックするための観点

外部AI・クラウド基盤を使う前に確認すること

観点	確認する問い
データ	何を渡すか。機微情報・顧客情報が含まれるか
権限	管理者・更新・ログ閲覧の権限は誰が持つか
法域	どの国の法律・開示命令の影響を受けるか
AI推論	プロンプト・社内文書はどこで処理されるか
退出	契約終了時に、データ・設定・ワークフロー・監査ログを取り出せるか

判断の視点

- 調達の合理性（能力・コスト・期間）だけでなく、「依存した後に退出できるか」 まで見る
- 外部サービスの利用は悪ではない
- ただし、確認しないまま使うと、あとから選択肢を失う

本件は、防衛の話だけではない

自分の会社でも同じ問いが立つ

- 顧客データ・業務データは、**どの国・どの事業者**の管理下にあるか
- **管理者権限・ログ閲覧権限・更新権限**は誰が持っているか
- AIに投げた**プロンプトや社内文書**は、どこで処理されるか
 - 利用サービスの裏側で使われているAIは、管理下か
- 契約終了時に、**データ・設定・ワークフロー**を取り出せるか

まとめると

- 「攻撃者はどのポイントから入れるか」を考えるのと同じように、「外部サービスはどのポイントでデータに触れるか」を考える
- **物理・法律・権限・退出**、この4層で整理すると見えなかったリスクが見える
- 何をどこまで許容するのかを決める。退出不能ならデータやフローごと廃棄できるのか、何を引き継がなければいけないのかの明確化と保護、など。

まとめ：データの支配条件を設計する

今日の話を3行で

- データ主権はサーバーの場所の話ではない
 - 誰の法が・誰の権限が・誰の判断が適用されるかの問題
- 「使う前に決める」が全て
 - 依存が固定化してからでは、選択肢を取り戻せない
- 外部サービスを使わないことが目的ではない
 - データ・権限・推論・退出の条件を確認した上で使う

見るべき4つの支配条件

- データはどこにあり、誰が管理するのか
- どの国の法律・開示命令の影響を受けるのか
- 管理者権限・更新権限・ログ閲覧権限は誰が持つのか
- やめるときに、データ・設定・ワークフローを取り戻せるか

ご清聴ありがとうございました

補足

- ウクライナの同様の支援システム「DELTA」とはどう違うのか
 - 正確な情報が無いので憶測になるが、DELTAは「多機能google map」というような意味合い、MavenSmartSystemは「意思決定システム」といった意味合いと言えると思われる
 - DELTAは、地図データに色々な情報を付与していくものと考えられる。その為、地図に表示しきれない国としての戦略部分に対する支援は限定的と考えられる。
- 別のデータ主権での戦場はあるのか
 - たとえば、脆弱性情報、が挙げられる
 - EUVD（European Vulnerability Dataase）のように、脆弱性情報に関する主権回復の施策

参考

- NATO SHAPE: "NATO acquires AI-enabled Warfighting System" (2025年4月14日)
 - <https://shape.nato.int/news-releases/nato-acquires-ai-enabled-warfighting-system->
- Palantir公式: "Palantir Announces Renewal of Multi-Year Contract with the DGSII" (2025年12月15日)
 - <https://investors.palantir.com/news-details/2025/Palantir-Announces-Renewal-of-Multi-Year-Contract-with-the-DGSII/>
- Republik / Swissinfo: スイス軍内部評価報道 (2024年)
 - <https://www.swissinfo.ch>
- 防衛省公式: 小泉防衛大臣の訪米動静 (2026年1月)
 - <https://www.mod.go.jp/en/article/2026/01/3eee3a5675cfbb9312ca9962baf1f5dc7547e1da.html>
- 外務省公式: ティール氏による高市総理大臣表敬 (2026年3月5日)
 - https://www.mofa.go.jp/mofaj/na/na2/us/pageit_000001_02778.html
- デジタル庁: ガバメントクラウド
 - https://www.digital.go.jp/policies/gov_cloud